



МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА – Российский технологический университет»

РТУ МИРЭА

ЛЕКЦИОННЫЕ МАТЕРИАЛЫ

Системы мониторинга и управления инцидентами информационной безопасности

	<i>(наименование дисциплины (модуля) в соответствии с учебным планом)</i>
Уровень	
	<i>(бакалавриат, магистратура, специалитет)</i>
Форма обучения	
	<i>(очная, очно-заочная, заочная)</i>
Направление(-я) подготовки	
	<i>(код(-ы) и наименование(-я))</i>
Институт	Институт кибербезопасности и цифровых технологий
	<i>(полное и краткое наименование)</i>
Кафедра	Интеллектуальные системы информационной безопасности
	<i>(полное и краткое наименование кафедры, реализующей дисциплину (модуль))</i>
Лектор	к.т.н., Урасков Юрий Леонидович
	<i>(сокращенно – ученая степень, ученое звание; полностью – ФИО)</i>
Используются в данной редакции с учебного года	2022/23
	<i>(учебный год цифрами)</i>
Проверено и согласовано « ____ » _____ 20__ г.	
	<i>(подпись директора Института/Филиала с расшифровкой)</i>

Москва 2022 г.

Лекция 7. Анализ систем SOAR

Непрерывное усложнение среды реагирования на инциденты в сфере ИБ влечёт за собой необходимость масштабирования операционной деятельности компаний, а также сокращения среднего времени принятия контрмер и повышения эффективности сервисов. Однако при этом, как следствие, возникают проблемы управления трудовыми ресурсами, процессами и технологиями. Эти проблемы обусловлены следующими факторами: сложные целевые атаки на информационные системы, большое разнообразие применяемых средств защиты информации, большое количество оповещений по безопасности как от систем управления ИБ-событиями, так и от других источников. Усложнилась сама природа атак, вышли на первый план направленные нападения, для детектирования которых необходимо сопоставлять не имеющие явных связей и разнесённые во времени события. На команды оперативных центров обеспечения кибербезопасности (Security Operations Center, SOC) обрушивается интенсивный поток инцидентов, количество задач стремительно растёт. Отсюда появилась потребность в выполнении шаблонных действий без участия человека, и возник соответствующий класс систем оркестровки, автоматизации и реагирования SOAR.

SOAR (Security Orchestration, Automation and Response) – класс программных продуктов, предназначенных для оркестровки систем безопасности, то есть их координации и управления ими. В частности, решения класса SOAR позволяют собирать данные о событиях информационной безопасности из различных источников, обрабатывать их и автоматизировать типовые сценарии реагирования на них.

К работе SOAR относится:

Оркестровка (Orchestration) – интеграция технологий и инструментов для принятия решений на основе информации об уровне риска и состоянии системы.

Автоматизация (Automation) – для замещения задач, которые ранее выполняли «вручную», автоматическими действиями со стороны системы по заготовленным сценариям (playbooks).

Управление киберинцидентами и совместная деятельность (Incident management and collaboration) – сквозной подход по работе с «назначением приоритета», «протоколированием действий» и «принятием решений на основе политик компании».

Формирование отчётов (Dashboards and reporting) – визуализация информации по ключевым метрикам и составление сводок для трёх типов сотрудников — аналитиков, руководителей SOC и директоров по ИБ (Chief Information Security Officer, CISO).



Рисунок 1. Основные функции SOAR-систем.

SOAR обладают функциональностью, позволяющей сократить время расследования значимых инцидентов в сфере ИБ. Это, в частности:

- интеграция технологий / инструментов, необходимых для принятия решений на основе отчётов о состоянии системы безопасности и оценки возможного уровня риска;
- автоматизация процессов;
- управление инцидентами с использованием сквозного подхода (определение приоритетов, регистрация всех действий по реагированию на инциденты, принятие решений в соответствии с политикой компании);
- визуализация данных, связанных с ключевыми показателями, отчётами сотрудников и документацией.

Огромным преимуществом использования SOAR является то, что они позволяют автоматизировать процессы управления инцидентами, начиная от назначения приоритетов и заканчивая собственно реагированием. Благодаря заранее созданным планам действий («плейбукам») система способна самостоятельно среагировать на то или иное происшествие, тем самым повысив точность и скорость выполнения операций. При этом следует обратить внимание на то, что автоматизация процессов реагирования при всей своей сложности и витиеватости должна быть гибкой и предусматривать включение человека в рабочий процесс, а иногда и вообще останавливаться, ожидая решения аналитика.

За счёт оркестровки SOAR обеспечивает скоординированный автоматический ответ на выявленную несанкционированную активность. Конечно, полностью решить проблему в автоматическом режиме не всегда представляется возможным, но SOAR должна быть способна переводить средства защиты в более строгие режимы работы, своевременно начинать сбор подробной статистики либо ограничивать операции, которые потенциально могут привести к утечкам данных. Кроме того, важно, чтобы SOAR умела обрабатывать и сортировать оповещения, поступающие от внешних систем (например, SIEM), вести детальный журнал, быть источником для создания

базы знаний о возможных атаках, предоставлять данные для аналитики и расследования инцидентов, и к тому же была готова к интеграции с платформами киберразведки (Threat Intelligence).

SOAR может интегрировать данные об угрозах, поступающие из разных источников. Это достигается с помощью трёх основных модулей, перечисленных далее.

- Модуль реагирования на инциденты в области безопасности (Security Incident Response, SIR) облегчает процесс выявления происшествий. Он также импортирует информацию из других применяемых решений и настраивает ИБ-процедуры.

- Для приоритизации уязвимостей продукты класса SOAR используют модуль Response Vulnerability. Он помогает определить степень подверженности критических бизнес-систем угрозам.

- Модуль анализа угроз на основе данных киберразведки предназначен для выявления признаков возможной компрометации, а также для углублённого отслеживания угроз. Его основное преимущество заключается в том, что он поддерживает различные стандарты, применяемые для обмена данными об угрозах. Кроме того, этот модуль позволяет добавлять пользовательские источники и обмениваться информацией с внешними системами.

Функциональные возможности решений класса SOAR

Сбор данных о потенциальных инцидентах. SOAR-системы способны агрегировать и обрабатывать ИБ-сигналы из множества источников, в число которых входят:

- SIEM-решения;
- Антивирусы и другое ПО для защиты конечных точек;
- DLP-продукты;
- Платформы для анализа угроз (Threat Intelligence);

- Система для анализа поведения пользователей (UEBA-решения);
- Межсетевые экраны;
- Службы каталогов ОС.

Анализ инцидента. При помощи автоматических сценариев или в ручном режиме решения класса SOAR дополняют информацию о киберинциденте данными из внешних баз, записей об аналогичных событиях и других источников. Также на этом этапе формируется перечень затронутых инцидентом объектов и устройств.

Идентификация и классификация угроз. На основании комплексного анализа полученных данных SOAR оценивает состояние инфраструктуры, выделяет потенциально небезопасные события, ранжирует их по степени риска и информирует о них специалистов. При необходимости система изолирует зараженные устройства, чтобы не допустить дальнейшего распространения атаки, или принимает иные меры, соответствующие политике компании.

Реагирование на инциденты. На основании информации об инциденте SOAR выполняет набор действий, необходимых для устранения угрозы или минимизации ее последствий. Это могут быть команды другим ИБ-продуктам, дистанционное удаление вредоносных объектов, восстановление ключей реестра и другие действия.

Визуализация данных и формирование отчетности. Большинство решений класса SOAR способны представлять сводную информацию о киберинцидентах по подразделениям компании, конечным точкам, программным продуктам или конкретным сотрудникам. Отчетность о текущем уровне безопасности организации формируется в виде наглядных диаграмм или информеров, обновляемых в режиме реального времени.

Разница между SOAR и SIEM

Решения для управления событиями и информацией о безопасности (SIEM) во многом похожи на SOAR-решения, в результате чего одно понятие иногда подменяют другим. Однако между ними есть существенная разница: в то время как SIEM-решения нацелены на сбор информации и ручное управление инцидентами, SOAR-системы рассчитаны на автоматизацию и оркестровку работы нескольких различных систем информационной безопасности, в частности, на этапе реагирования. В результате SIEM-решения отлично дополняют SOAR в качестве источника информации о событиях.

Мировой рынок SOAR

В исследовании «Security Orchestration Automation and Response (SOAR) Market Size» ожидается, что к 2025 году объём рынка SOAR достигнет 2,3 млрд долларов США, в среднем ежегодно увеличиваясь на 16,3 %. На рост рынка влияют такие факторы, как рост числа кибератак, нехватка персонала, требования законодательства, отсутствие у сотрудников необходимых компетенций по обнаружению угроз и атак. Всё это вносит значительный вклад в развитие рынка SOAR.

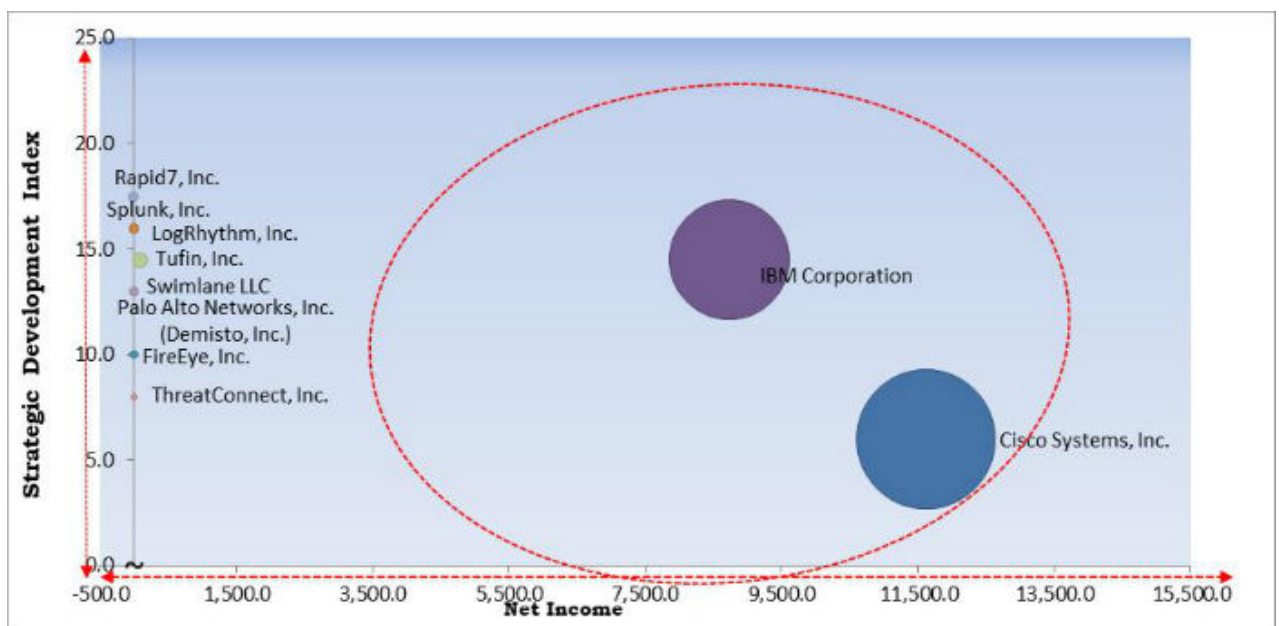


Рисунок 2. Матрица KBV Research для рынка SOAR.

Таким образом, согласно исследованиям MarketsandMarkets и KBV Research, а также руководству Gartner «Market Guide for Security Orchestration, Automation and Response Solutions», на мировом рынке можно выделить следующие предложения:

- ATAR SOAR Platform;
- Ayehu NG Platform;
- CyberSponse CyOPs;
- Cisco SecureX;
- Cyberbit SOC 3D;
- Palo Alto Networks Cortex XSOAR (ранее продукт назывался Demisto SOAR);
- IBM Resilient SOAR;
- FireEye Helix Platform;
- Fortinet FortiSOAR;
- D3 Security D3 SOAR;
- DFLabs IncMan; EclecticIQ Platform;
- Exabeam Security Management Platform;
- LogRhythm RespondX SOAR Platform;
- Micro Focus ArcSight SOAR;
- Splunk Phantom; Rapid7 InsightConnect;
- Resolve; ServiceNow Security Operations;
- Siemplify; Swimlane;
- Syncurity IR Flow;
- ThreatConnect;
- ThreatQ ThreatQuotient;
- Tufin Orchestration Suite;
- R-Vision IRP;
- Security Vision IRP / SOAR («Интеллектуальная безопасность»);
- UserGate 5 (NGFW с функциями SOAR).

Выводы

В условиях постоянно расширяющегося потока сообщений о возможных инцидентах и стремительного проведения современных кибератак эффективное реагирование становится невозможным без автоматизации выполняемых действий и применения готовых алгоритмов.

Использование систем SOAR позволит:

- повысить эффективность обработки сложных инцидентов за счёт дополнительной видимости конечных точек, возможности проактивного поиска угроз и наглядного представления информации об обнаруженных событиях в сети;
- обогатить базу SOC предварительно обработанными релевантными данными для сопоставления с журналами, поступающими из других источников, для эффективного расследования;
- значительно сократить количество часов, затрачиваемых аналитиками на утомительные, но необходимые задачи, связанные с проверкой данных от рабочих мест и серверов, а также с реагированием на инциденты.

Рынок СОАР весьма молод, и игроков на нём пока не очень много, хотя в дополнение к зарубежным разработкам уже появляются и российские решения. При этом, учитывая развитие направлений, связанных с SOC и ГосСОПКА, можно утверждать, что решения класса СОАР актуальны для отечественных заказчиков и дальнейший спрос на них будет только расти. Это, несомненно, должно положительно сказаться на развитии российского рынка таких продуктов.